

Welcome to

Network Attacks I – Concepts

Cyber Akademiet, 2026

Henrik Kramselund he/him han/ham hlk@zencurity.com @kramse

Slides are available as PDF, https://codeberg.org/kramse
academy-2026-day1-network-attacks-I.tex in the repo security-courses

© license CC BY 3.0. 2026 Henrik Kramselund

Goals for today



- Explain network-attack concepts: botnets, DoS and DDoS
- Explain amplification/reflection and SYN/UDP/ICMP flooding
- Explain ARP poisoning and man-in-the-middle risks
- Recognise real attack cases and the TCP/IP protocol weaknesses behind them

Plan for today



- Attack overview and the DDoS problem
- Real incidents and CVEs
- TCP/IP protocol weaknesses
- ARP poisoning, MITM, DNS and SNMP

Time schedule



- 08:30–10:00 Attack overview, DDoS, real cases
- 10:00–10:15 Break
- 10:15–11:45 Protocol attacks: ARP/MITM, TCP/IP, DNS, SNMP
- 11:45–12:30 **Exercise** (booklet)
- 12:30–13:15 Lunch

Introduction: Attack overview



Source: http://www.sicherheitstacho.eu/

The Internet and DDoS is trouble



Security attacks and DDoS is very much in the media



Source: Netscout Global DDoS Threat Intelligence Report 2nd half 2021

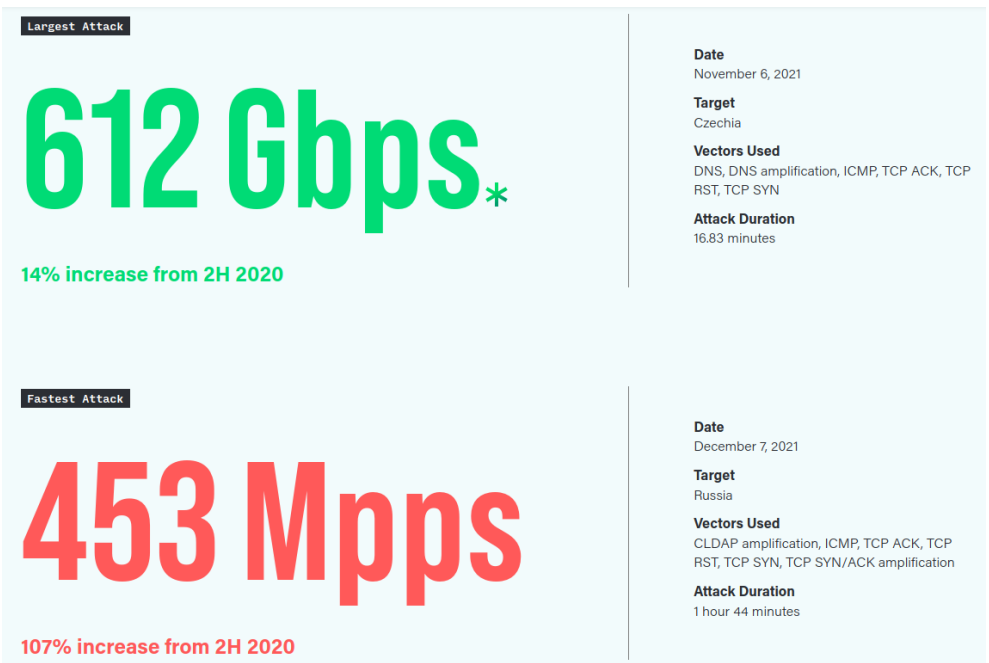
https://www.netscout.com/threatreport/global-ddos-attack-trends/

DDoS Attacks Still a Problem



Security attacks and DDoS is very much in the media
Source: linkhttps://www.netscout.com/threatreport/global-ddos-attack-trends/

DDoS Attacks are HUGE



Extremely hard to protect against from a small network

Source: https://www.netscout.com/threatreport/global-ddos-attack-trends/

Availability and Network flooding attacks



The attacks we are discussing today are:

- **SYN flood** is the most basic and very common on the internet towards 80/tcp and 443/tcp
- **ICMP and UDP flooding** are the next popular targets – more similar ones exist
- Special packets and protocols – anything that can create *load on systems* work
- All of them try to use up some resources
- **Memory space** in specific sections of the **kernel, TCP state, firewalls state, number of concurrent sessions/connections**
- **Interrupt processing** of packets - packets per second (pps)
- **CPU processing** in firewalls, pps
- CPU processing in server software
- **Bandwidth** - megabits per second (mbps)
- Typically source is spoofed or amplification attacks abusing devices on the Internet

Botnets



- **FIXME:** add botnet concept + accurate example (e.g. Mirai)

Amplification & reflection



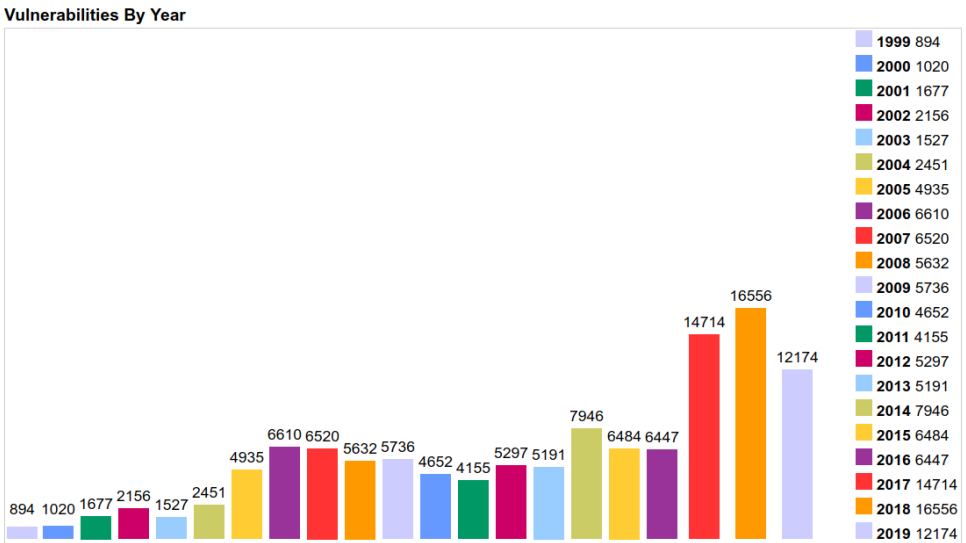
- **FIXME:** reflection with spoofed source; amplification factor (e.g. DNS)

SYN / UDP / ICMP flooding



- **FIXME:** per-flood concept (shown hands-on in part II), subject plan obj 9

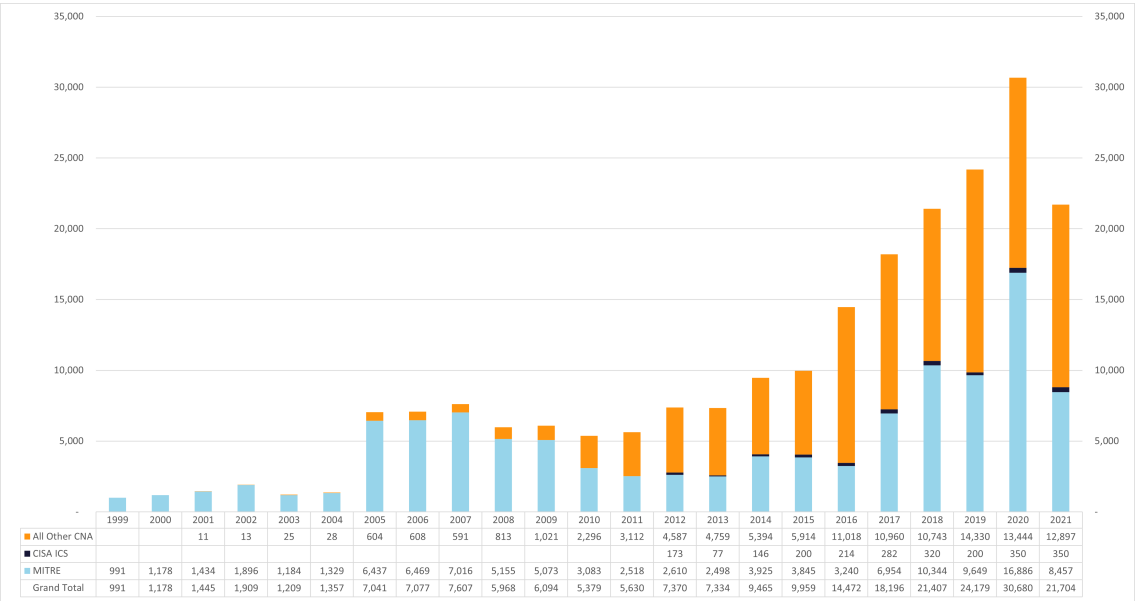
MITRE – Common Vulnerabilities and Exposure (CVE)



The mission of the CVE® Program is to identify, define, and catalog publicly disclosed cybersecurity vulnerabilities.

20 years and one of the most critical projects for internet and information security, in my opinion

OMG CVE



	1999	2000	2001	2002	2003	2004	2005	2006	2007	2008	2009	2010	2011	2012	2013	2014	2015	2016	2017	2018	2019	2020	2021
All Other CNA			11	13	25	28	604	608	591	813	1,021	2,296	3,112	4,587	4,759	5,394	5,914	11,018	10,960	10,743	14,330	13,444	12,897
CISA ICS														173	77	146	200	214	282	320	200	350	350
MITRE	991	1,178	1,434	1,896	1,184	1,329	6,437	6,469	7,016	5,155	5,073	3,083	2,518	2,610	2,498	3,925	3,845	3,240	6,954	10,344	9,649	16,886	8,457
Grand Total	991	1,178	1,445	1,909	1,209	1,357	7,041	7,077	7,607	5,968	6,094	5,379	5,630	7,370	7,334	9,465	9,959	14,472	18,196	21,407	24,179	30,680	21,704

Source: https://www.cve.org/Media/News/item/blog/2021/11/16/CVE-Program-Report-for-Q3

- How many can you handle per day? How many are relevant for your organisation?

March 2021: ProxyLogon/ProxyShell CVE-2021-26855 CVSS:3.0 9.1 / 8.4



In March 2021, both Microsoft and IT Professionals had a major headache in the form of an Exchange zero-day commonly known as ProxyLogon. The vulnerability, widely considered the **most critical to ever hit Microsoft Exchange**, was quickly exploited in the wild by suspected state-sponsored threat actors, with US government and military systems identified as the most targeted sectors. **Ransomware variants such as DoejoCrypt were soon actively exploiting unpatched Exchange instances**, attempting to monetise the vulnerability.

A follow-up exploit, dubbed ProxyShell, was evolutionary in nature and targeted on-premise Client Access Servers (CAS) in **all supported versions of Exchange Server.** Due to the **remotely accessible nature of Exchange CAS, any unpatched instances would be vulnerable to Remote Code Execution. High profile victims included the European Banking Authority and the Norwegian Parliament.**

Source - for this description:
https://chessict.co.uk/resources/blog/posts/2022/january/2021-top-security-vulnerabilities/

June 2021: PrintNightmare CVE-2021-34527 CVSS:3.0 8.8 / 8.2



In June, Microsoft released a critical security update to address weaknesses in the Printer Spooler service on Windows desktop and server platforms. Unfortunately, it was released out-of-band outside of the standard patch Tuesdays due to the severity. Microsoft even released patches for Windows 7, an supported operating system that does not normally receive updates.

Initially categorised by Microsoft as a local privilege escalation on Windows, security researchers subsequently identified an additional **Remote Code Execution (RCE)** vector resulting in an updated advisory from Microsoft. As ever, the ability to test and deploy patches in a time-sensitive manner is key to minimising the impact of such vulnerabilities.

Additionally, PrintNightmare had the additional horror factor of dropping during the **summer holiday season in the northern hemisphere**. Our consultants continue to see systems vulnerable to PrintNightmare on client engagements, which can be trivially leveraged to obtain privilege escalation on unpatched Windows systems.

Source - for this description:
https://chessict.co.uk/resources/blog/posts/2022/january/2021-top-security-vulnerabilities/

See also https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-34527

November 2021: Log4Shell



It would not be possible to discuss 2021 in the context of vulnerabilities without the mention of Log4Shell. **A widely used Java-based logging library caused headaches for Security professionals worldwide**. Many scrambled to quantify their use of Log4j within their estates.

A zero-day exploit quickly followed, confirming the worst - **Remote Code Execution (RCE) was indeed possible.** However, what made the nature of the vulnerability even more challenging was the ability to exploit a backend logging system from an unaffected front end host. For example, an attacker can craft a weaponised log entry on a mobile app or webserver not running Log4j. The attacker could make their way through to backend middleware itself running Log4j, which significantly extends the attack surface of the vulnerability.

The NCSC even took the step of recommending the update was immediately applied, whether or not Log4Shell was known to be in use. As is commonly the case with critical vulnerabilities, two successive Log4j patches were subsequently released in the week following the original addressing Denial of Service (DoS) and a further RCE. This further increased workloads of Security and IT teams just as they thought the worst of 2021 had been and gone.

Source - for this description:
https://chessict.co.uk/resources/blog/posts/2022/january/2021-top-security-vulnerabilities/

See also https://en.wikipedia.org/wiki/Log4Shell

The Internet Worm 2. nov 1988



Exploited the following vulnerabilities

- buffer overflow in fingerd - VAX code
- Sendmail - DEBUG functionality
- Trust between systems: rsh, rexec, ...
- Bad passwords

Contained camouflage!

- Program name set to 'sh'
- Used fork() to switch PID regularly
- Password cracking using intern list of 432 words and /usr/dict/words
- Found systems to infect in /etc/hosts.equiv, .rhosts, .forward, netstat ...

Made byRobert T. Morris, Jr.

Stuxnet



Worm in 2010 intended to infect Iran nuclear program

Target was the uranium enrichment process

Infected other industrial sites

SCADA, and Industrial Control Systems (ICS) are becoming very important for whole countries

A small *community* of consultants work in these *isolated* networks, but can be used as infection vector - they visit multiple sites

More can be found in https://en.wikipedia.org/wiki/Stuxnet

MITRE ATT&CK framework



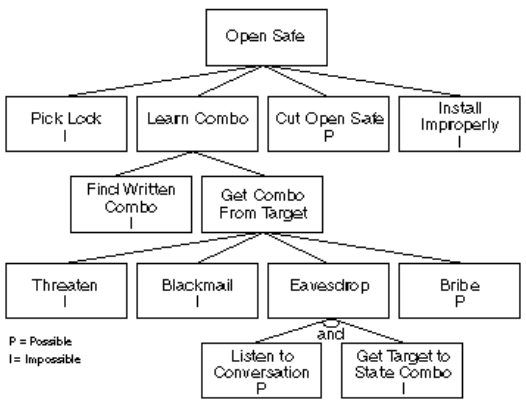
MITRE ATT&CK™ is a globally-accessible knowledge base of adversary tactics and techniques based on real-world observations. The ATT&CK knowledge base is used as a foundation for the development of specific threat models and methodologies in the private sector, in government, and in the cybersecurity product and service community.

With the creation of ATT&CK, MITRE is fulfilling its mission to solve problems for a safer world — by bringing communities together to develop more effective cybersecurity. ATT&CK is open and available to any person or organization for use at no charge.

ATT&CK™

Great resource for attack categorization https://attack.mitre.org/

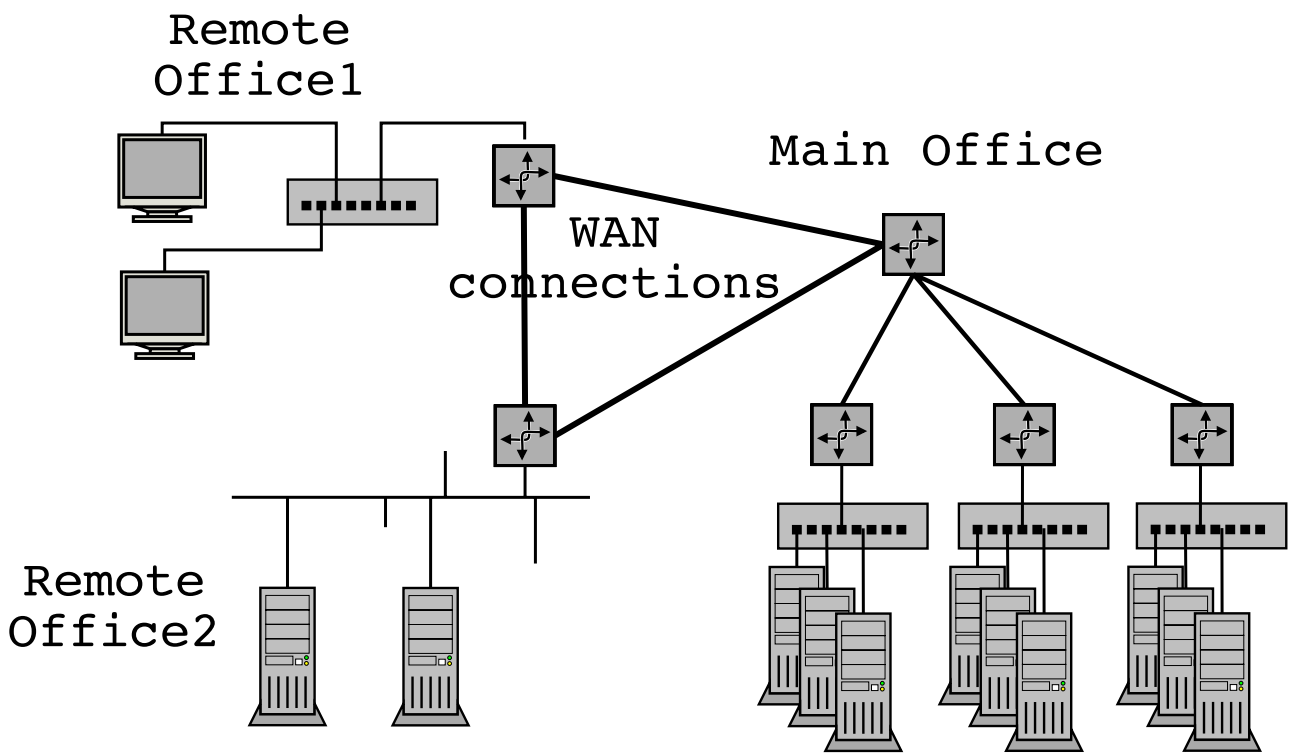
Attack trees



- Attacks can be said to be based on a chain of dependencies, or graphs
- To achieve goal, need to achieve sub goal x, y, and z – Break the chain and the attack fails!
- Simple example, installing updates remove a dependency for a vulnerability
- Attack trees, picture from Bruce Schneier Attack Trees article December 1999:

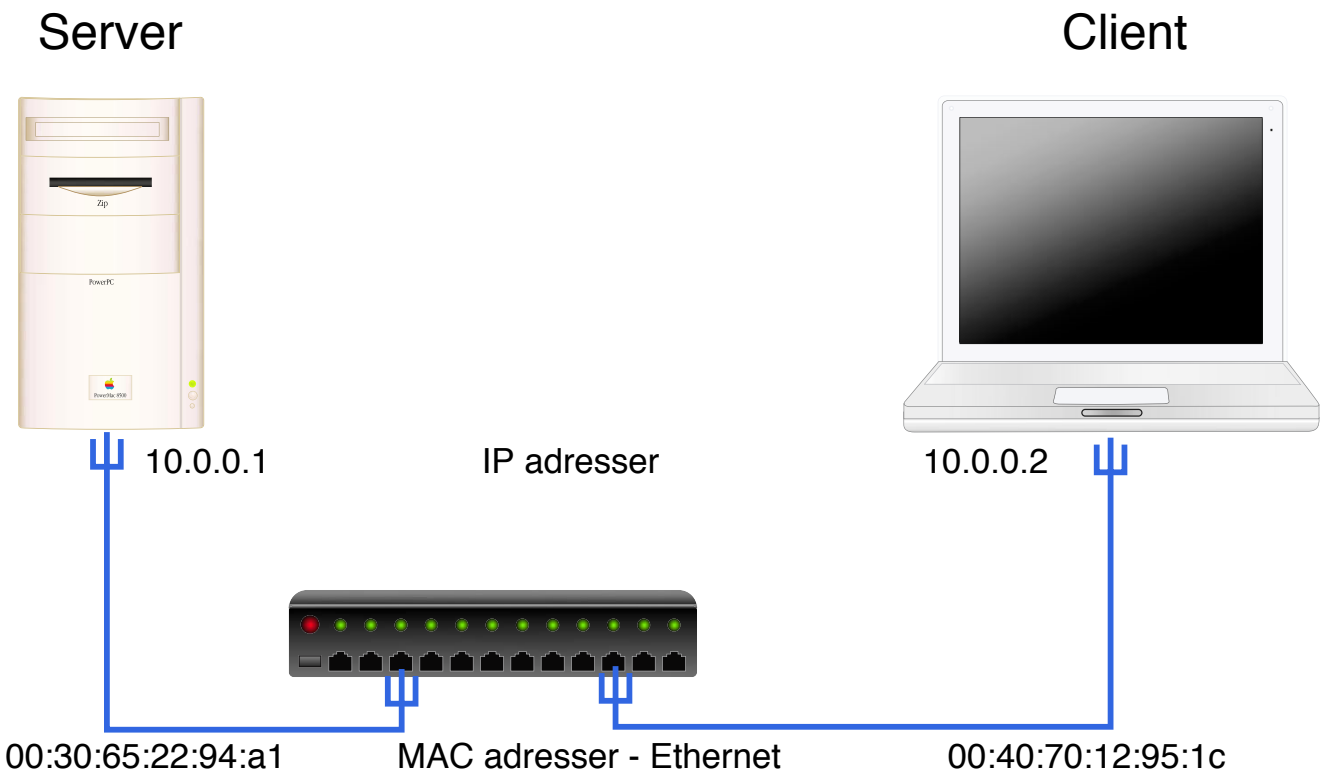
  https://www.schneier.com/academic/archives/1999/12/attack_trees.html

Common Networks – spans multiple locations, regions, user bases



Fysisk er der en begrænsing for hvor lange ledningerne må være

Address Resolution Protocol (ARP)



Person in the middle attacks



ARP spoofing, ICMP redirects, the classics

Used to be called Man in The Middle MiTM

- ICMP redirect
- ARP spoofing
- Wireless listening and spoofing higher levels like airpwn-ng https://github.com/ICSec/airpwn-ng

Usually aimed at unencrypted protocols

Today we only talk about getting the data, not how to perform higher level attacks

Security problems in the TCP/IP Suite



The title of a nice paper, and the rest of today

> The paper "Security Problems in the TCP/IP Protocol Suite" was originally pub- lished in Computer Communication Review, Vol. 19, No. 2, in April, 1989

Problems described in the original:

- sequence number spoofing
- routing attacks,
- source address spoofing
- authentication attacks

TCP sequence number prediction



> TCP SEQUENCE NUMBER PREDICTION One of the more fascinating security holes was first described by Morris [7] . Briefly, he used TCP sequence number prediction to construct a TCP packet sequence without ever receiving any responses from the server. This allowed him to spoof a trusted host on a local network.

tidligere baserede man login/adgange på source IP adresser, address based authentication

Er ikke en pålidelig autentifikationsmekanisme

Mest kendt er nok Shimomura der blev hacket på den måde,
måske af Kevin D Mitnick eller en kompagnon

I praksis vil det være svært at udføre på moderne operativsystemer

Se evt. http://www.takedown.com/ (filmen er ikke så god ;-))

Det er naturligvis fint med filtre så man kun kan tilgå services FRA bestemte IP

Routing attacks



Problems described in the original from 1989:

- IP Source routing attacks - angiv en rute for pakkerne
  Knapt så brugbar idag
- Routing Information Protocol Attacks
  The Routing Information Protocol [15] (RIP) - denne bruges ikke mere, outdated
- BGPv4 som bruges idag har kæmpe problemer, kludetæppe af kludges

Vi kommer til at snakke om https://github.com/tomac/yersinia

DNS problems



> The Domain Name System (DNS) [32][33] provides for a distributed database mapping host names to IP addresses. An intruder who interferes with the proper operation of the DNS can mount a variety of attacks, including denial of service and password collection. There are a number of vulnerabilities.

We have a lot of the same problems in DNS today

Plus some more caused by middle-boxes, NAT, DNS size, DNS inspection

- DNS must allow both UDP and TCP port 53
- Your DNS servers must have updated software, see DNS flag day https://dnsflagday.net/ after which kludges will be REMOVED!

SNMP problems



> 5.5 Simple Network Management Protocol The Simple Network Management Protocol (SNMP) [37] has recently been defined to aid in network management. Clearly, access to such a resource must be heavily protected. The RFC states this, but also allows for a null authentication service; this is a bad idea. Even a "read-only" mode is dangerous; it may expose the target host to netstat-type attacks if the particular Management Information Base (MIB) [38] used includes sequence numbers. (T

True, and we will talk more about SNMP later in this course.

Summary



- Network attacks: flooding (availability) and protocol abuse (ARP, TCP/IP, DNS, SNMP)
- Next: the hands-on half – generate and defend against these